

Portfolio Security Report

Consolidated Batch Summary

Company:

ACME Cyber Risk

Report

Type:

Consolidated

Timestamp:

—

Session:

Z FQ JW

Executive Summary

The recent security analysis of our repositories indicates a moderate risk posture, with a focus on high-severity findings. The majority of issues are concentrated in a few repositories, suggesting targeted remediation could significantly reduce overall risk.

- **13** repositories scanned
- **238** total files analyzed
- **10** files flagged, representing **4.20%** of total files
- **23.08%** of repositories contain findings
- Top categories: **py_file_op_tainted** (7), **py_subprocess_tainted** (2), **high_entropy_candidate** (1)
- **69.23%** of findings are high severity
- Median flagged files per repo: **0.0**; 95th percentile: **6.0**

Portfolio-Level Statistics

Metric	Total	Rate (%)
Repositories	13	N/A
Files Scanned	238	N/A
Flagged Files	10	4.20
Repos with Findings	3	23.08

Category	Count	% of Total
py_file_op_tainted	7	70.00
py_subprocess_tainted	2	20.00
high_entropy_candidate	1	10.00

Severity	Count	% of Total
High	9	90.00
Medium	1	10.00

Distribution Highlights:

- Top 5 Repos by Flagged Count:

- JamesonRGrieve/ServerFramework: 6
- Lekssays/joern-mcp: 2
- aparsoft/kokoro-mcp-server: 2
- aryaminus/h1b-job-search-mcp: 0
- ohnicholas93/payload-mcp-server: 0

Systemic Risks & Themes

- **File Operation Tainting:** Predominantly in JamesonRGrieve/ServerFramework.
- **Subprocess Tainting:** Detected in Lekssays/joern-mcp and aparsoft/kokoro-mcp-server.
- **High Entropy Strings:** Potential secrets in JamesonRGrieve/ServerFramework.

Prioritized Recommendations

- **P0:** Immediate review and remediation of high-severity findings in JamesonRGrieve/ServerFramework (Owner: JamesonRGrieve; Success: No high-severity findings post-remediation).
- **P1:** Implement automated secret scanning in CI/CD pipelines.
- **P2:** Enhance training on secure coding practices, focusing on file and subprocess handling.

Notable Repositories

- **Standout-Safe:** aryaminus/h1b-job-search-mcp and ohnicholas93/payload-mcp-server (No findings).
- **Higher-Risk:** JamesonRGrieve/ServerFramework (High concentration of high-severity findings).

Methodology Notes

- **Scope:** Static analysis of 13 repositories.
- **Exclusions:** Dynamic analysis not performed; evidence excerpts are redacted.
- **Caveats:** Assumptions made when findings data was incomplete, relying on flagged counts.